École Supérieure des Communications de Tunis
SUP'COM

TupleTrace

BESOINS FONCTIONNELS ET SRE

Plateforme sécurisée de partage de jeux de données traçables

Fonctionnalités, exigences de sécurité, fiabilité et robustesse du code métier

Module : Sécurité Applicative — Atelier PWA/SPA
Socle : Jakarta EE 11 — WildFly 42 — Java 25
Année universitaire : 2026–2027
Version : 2.0 — 11/11/2026

Réalisé par :
OMRANE Yosr
AMMAR Cheima
BEN AMOR Hayet

Encadré par :
Dr. Ing. Mohamed-Becha KAÂNICHE

Table des matières

1 Introduction **3**
1.1 Objet du document . . . 3
1.2 Articulation avec le cahier des charges . . . 3
1.3 Organisation . . . 3
1.4 Conventions . . . 4
1.5 Justification de l'approche SRE . . . 4
1.6 Application des neuf étapes SQUARE à TupleTrace . . . 4
1.7 Livrables et traçabilité de SQUARE . . . 4

2 Description fonctionnelle **5**
2.1 Module Socle . . . 5
2.2 Module Jeux de données . . . 5
2.3 Module Watermarking . . . 5
2.4 Module Stéganographie . . . 6
2.5 Module Fingerprinting . . . 6
2.6 Module Investigation . . . 6
2.7 Module Administration . . . 7
2.8 Module PWA . . . 7

3 API REST **7**

4 Référentiel des exigences de sécurité (SR) **8**
4.1 Lecture du référentiel . . . 8
4.2 CON — Confidentialité et secrets . . . 8
4.3 INT — Intégrité des données, du marquage et des verdicts . . . 9
4.4 NRP — Non-répudiation et preuves . . . 10
4.5 AUT — Authentification . . . 10
4.6 AUZ — Autorisation . . . 10
4.7 PRV — Vie privée et confidentialité des associations . . . 11
4.8 LOG — Journalisation et audit . . . 11
4.9 ERR — Gestion des erreurs . . . 11
4.10 DIS — Disponibilité et résilience du code métier . . . 12
4.11 TST — Vérification et preuves . . . 12
4.12 DEP — Déploiement et chaîne de livraison . . . 12

5 Cotation des risques (OWASP Risk Rating) **13**

6 Indicateurs SLI et objectifs SLO du code métier **14**
6.1 SLI et SLO initiaux . . . 14
6.2 Protocole de mesure . . . 15
6.3 Lecture des indicateurs . . . 15

7 Campagnes de vérification **16**
7.1 Principes . . . 16
7.2 Catalogue des campagnes . . . 16

8 Traçabilité **17**
8.1 Modules fonctionnels et exigences de sécurité . . . 17
8.2 Cas d'abus, exigences et campagnes . . . 18

9 Gestion des exigences et inspection croisée **18**
9.1 Statuts . . . 18
9.2 Checklist d'inspection . . . 18
9.3 Conflits résolus . . . 19

10 Risques liés à la fiabilité et risques résiduels **19**
10.1 Risques de fiabilité . . . 19
10.2 Risques résiduels du MVP . . . 19

1. Introduction

1.1 Objet du document

Ce recueil réunit les besoins fonctionnels de TupleTrace (ce que la plateforme doit faire, pour qui et dans quel ordre), le référentiel des exigences de sécurité (SR) et l'approche SRE du projet.

Dans ce document, **SRE (Security Requirements Engineering)** désigne l'ingénierie des exigences de sécurité. Elle consiste à identifier les actifs, analyser les menaces, formuler et prioriser des exigences de sécurité précises et en vérifier la satisfaction. Pour TupleTrace, la méthode principale est **SQUARE adapté**, complétée par les cas d'abus, STRIDE et OWASP Risk Rating. Cette démarche alimente le référentiel SR de la section 4.

En complément, la **fiabilité et la résilience du code métier** de dissimulation (marquage, extraction, attribution) font l'objet d'indicateurs SLI et d'objectifs SLO, décrits en section 6. Il ne faut pas confondre cet objectif de fiabilité applicative avec l'ingénierie des exigences de sécurité ni avec la haute disponibilité de l'infrastructure (hors périmètre).

1.2 Articulation avec le cahier des charges

Le recueil complète le cahier des charges et partage ses identifiants (OM, BF, ENF, SR, CA, P1 à P6, F1 à F4). Pour conserver un vocabulaire et des identifiants communs sans répéter tout le contenu, ce recueil renvoie aux sections du cahier des charges qui présentent déjà les éléments suivants :

Contenu porté par le cahier des charges	Référence
Objectifs métier OM-1 à OM-5	CdC §3.1
Objectifs de sécurité, actifs et besoins C-I-D, profils d'attaquants P1 à P6	CdC §3.2, §10.1, §10.2
Périmètre inclus, acteurs, rôles et matrice des droits	CdC §4, §5
Méthode de marquage, contrôles avant publication, états d'une distribution	CdC §6
Scénario nominal et scénarios de refus (ambiguïté de clé, insuffisance statistique)	CdC §7
Exigences non fonctionnelles ENF-01 à ENF-11	CdC §8.1
Socle technique, architecture, mémoire et concurrence sous WildFly 42 / Java 25, frontières F1 à F4	CdC §9
Cas d'abus CA-01 à CA-18, STRIDE, arbres d'attaque, transformations relationnelles	CdC §10.3 à 10.8
Banc d'essai, simulateur de transformations, indicateurs, critères de recette	CdC §11.1 à 11.4
Risques projet et conclusion	CdC §12

1.3 Organisation

— **Besoins fonctionnels** (sections 2 et 3) : modules, besoins BF et API REST. Les limites du périmètre sont détaillées dans le cahier des charges.

— **Sécurité** (sections 4 et 5) : référentiel SR et cotation OWASP Risk Rating.

— **Fiabilité et vérification** (sections 6 et 7) : SLI et SLO du code métier, protocole des campagnes de mesure.

— **Traçabilité et pilotage** (sections 8 à 10 et annexe) : traçabilité, inspection croisée, risques résiduels et correspondance avec la version initiale.

1.4 Conventions

— **Priorités.** Les besoins BF suivent MoSCoW (M = Must, S = Should, C = Could). Les exigences SR utilisent P1 (indispensable au MVP) ou P2 (souhaitable), comme dans le cahier des charges (§10.6). Ces niveaux de priorité ne doivent pas être confondus avec les profils d'attaquants P1 à P6 du cahier des charges.

— **Statuts.** Une exigence est *proposée*, *validée*, *implémentée*, *vérifiée* ou *à revoir* (section 9). Toutes les exigences de ce document sont *proposées* tant qu'un test exécuté n'a pas conservé ses observations.

— **Cible n'est pas résultat.** Toute valeur chiffrée est une cible ou une valeur de départ, à confirmer au jalon J2 sur une machine et une JVM déclarées.

1.5 Justification de l'approche SRE

Nous avons choisi SQUARE pour organiser l'ingénierie des exigences de sécurité dès la conception. Cette méthode relie les objectifs du système aux actifs, aux menaces, aux exigences priorisées et à leur vérification. Elle convient à TupleTrace car une authentification correcte ne suffit pas à préserver les preuves portées par les tuples. Nous la complétons par des cas d'abus (notamment les initiés), STRIDE pour les flux et OWASP Risk Rating pour la priorisation.

1.6 Application des neuf étapes SQUARE à TupleTrace

1. **Définitions communes :** formaliser tuple, pk, attribute_id, watermark, sceau, fingerprint et attribution.
2. **Objectifs :** protéger les données, les clés, le registre et les verdicts tout en préservant leur utilité métier.
3. **Artefacts :** établir actifs C-I-D, acteurs, frontières F1 à F4, cas d'abus CA-01 à CA-18 et flux des données.
4. **Évaluation des risques :** examiner notamment l'IDOR, les collisions de tuples, les initiés et la saturation de la Heap ; conserver les cotations argumentées.
5. **Élicitation :** relire les scénarios normaux et abusifs avec les contraintes de Jakarta EE, Java 25 et du moteur de marquage.
6. **Spécification :** écrire les exigences SR sous la forme acteur/condition/comportement observable/test.
7. **Catégorisation :** classer les SR en onze familles (CON, INT, NRP, AUT, AUZ, PRV, LOG, ERR, DIS, TST, DEP).
8. **Priorisation :** classer en P1/P2 suivant les risques métier, l'effet sur les preuves et le périmètre MVP.
9. **Inspection :** confronter exigences, cas d'abus et campagnes de vérification lors de la revue croisée.

1.7 Livrables et traçabilité de SQUARE

Les produits de cette démarche sont le registre des actifs, les cas d'abus, les exigences SR, le registre des risques et la matrice reliant chaque besoin à ses menaces, contre-mesures et tests. Les éléments non encore testés restent au statut "proposé" ; le passage au statut "vérifié" nécessite une preuve

d'exécution archivée.

2. Description fonctionnelle

Les priorités suivent la méthode MoSCoW (M = Must, S = Should, C = Could). Le projet compte 35 besoins fonctionnels, présentés par module.

2.1 Module Socle

Les comptes ne sont pas ouverts librement : un destinataire est invité par une organisation, une organisation est validée par l'administrateur.

ID	Fonctionnalité	Prio
BF-CPT-01	**Activer un compte** — l'utilisateur active son compte depuis l'invitation reçue ; une organisation crée un compte soumis à validation.	M
BF-CPT-02	**Se connecter / se déconnecter** — e-mail + mot de passe, puis second facteur si activé ou obligatoire pour le rôle.	M
BF-CPT-03	**Gérer le second facteur** — activer un TOTP et obtenir des codes de secours.	M
BF-CPT-04	**Réinitialiser le mot de passe** — demande par e-mail, lien à usage unique.	M
BF-CPT-05	**Gérer ses données personnelles** — consulter, exporter, fermer son compte (le registre de distribution est conservé).	S

2.2 Module Jeux de données

Un jeu n'est jamais modifié en place : chaque protection produit une nouvelle version, rattachée au hash de l'original.

ID	Fonctionnalité	Prio
BF-JDD-01	**Importer un CSV** — validation du format, de l'encodage UTF-8, du séparateur, de la taille ($\leq$ 50 Mo, $\leq$ 1 000 000 lignes) ; rejet des clés dupliquées ou nulles et des en-têtes dupliqués ; contrôle des risques de formules à l'export tableur sans altérer les nombres négatifs à l'import ; chaque champ est mappé vers un attribute_id du schéma, la colonne de clé stable étant déclarée.	M
BF-JDD-02	**Importer une table PostgreSQL autorisée** — liste blanche de tables lues avec un compte en lecture seule ; l'import conserve les types et la clé primaire désignée ; un import sans clé stable est refusé pour le MVP. Reportable au profit du seul CSV si le flux n'est pas réalisable au MVP (CdC §1.1).	S
BF-JDD-03	**Profiler les colonnes** — type, plage, statistiques simples (moyenne, variance, min, max).	M
BF-JDD-04	**Définir colonnes marquables et tolérances** — une colonne interdite (identifiant, catégorie, date, code) ne peut pas être sélectionnée.	M
BF-JDD-05	**Conserver les versions et le hash SHA-256 de l'original.**	M

2.3 Module Watermarking

Le marquage est refusé plutôt que de dépasser une tolérance.

ID	Fonctionnalité	Prio
BF-WM-01	**Marque commune** — insertion du filigrane lié à la clé du propriétaire dans l'ensemble de lignes A.	M
BF-WM-02	**Rapport de qualité** — erreurs moyenne/maximale par colonne, effet sur moyenne et variance.	M
BF-WM-03	**Refus motivé** si une tolérance ne peut être respectée ou si le jeu est trop petit.	M

2.4 Module Stéganographie

Le jeu porte sa propre preuve d'authenticité, vérifiable même sans le registre.

ID	Fonctionnalité	Prio
BF-STG-01	**Sceau caché** — métadonnées signées (Ed25519) et chiffrées (AES-256-GCM), insérées dans l'ensemble B avec code correcteur.	M
BF-STG-02	**Afficher les métadonnées extraites** du sceau à côté de celles du registre, pour comparaison par l'enquêteur.	M
BF-STG-03	**Vérification autoportée** — authenticité vérifiable si le jeu est introuvable au registre (base indisponible, instance partenaire), sous réserve du droit de déchiffrement et de la racine de confiance (CdC §6.3).	S

2.5 Module Fingerprinting

Le gestionnaire prépare, le propriétaire valide : aucune copie n'est générée sans deux personnes différentes.

ID	Fonctionnalité	Prio
BF-FP-01	**Gérer les destinataires et leurs autorisations** (organisation inscrite, finalité, durée de validité).	M
BF-FP-02	**Préparer une distribution** — jeu protégé, destinataires, quotas.	M
BF-FP-03	**Valider et générer les copies** — validation par un propriétaire $\neq$ préparateur ; une empreinte distincte par copie.	M
BF-FP-04	**Téléchargement contrôlé** — lien temporaire à usage limité, lié au destinataire authentifié ; l'original non marqué n'est jamais téléchargeable.	M
BF-FP-05	**Révoquer un accès** — empêche tout nouveau téléchargement (n'efface pas une copie déjà obtenue).	M
BF-FP-06	**Registre de distribution signé** — copie, destinataire, hash, date ; historique consultable par les rôles habilités.	M

2.6 Module Investigation

Une conclusion incertaine est annoncée comme telle ; aucun résultat faible n'est présenté comme une attribution.

ID	Fonctionnalité	Prio
BF-INV-01	**Soumettre un extrait** — vérification du format, du schéma, de la taille ; repérage des lignes et colonnes exploitables.	M
BF-INV-02	**Rechercher la marque du propriétaire** par test statistique (p-value affichée).	M
BF-INV-03	**Identifier une empreinte** parmi les distributions autorisées, avec correction de Bonferroni.	M
BF-INV-04	**Verdict à quatre statuts** : Marque reconnue · Copie identifiée · Indéterminé · Aucune marque détectée, avec niveau de confiance et réserves.	M

BF-INV-05	**Rapport d'investigation signé** (méthode, données exploitées, résultats, limites).	M
BF-INV-06	**Simulateur de transformations** — suppression de lignes/colonnes, échantillonnage, arrondi, bruit, réordonnancement.	M
BF-INV-07	**Métriques de qualité et de robustesse** (taux de détection, faux positifs, précision d'attribution, temps).	S

2.7 Module Administration

L'administration gère la plateforme sans pouvoir toucher aux données ni aux clés ; l'audit est confié à un rôle distinct.

ID	Fonctionnalité	Prio
BF-ADM-01	**Gérer comptes et organisations** — valider, suspendre, attribuer les rôles plateforme.	M
BF-ADM-02	**Gérer les quotas** — traitements par organisation, téléchargements par destinataire, investigations par enquêteur.	S
BF-ADM-03	**Consulter l'audit** — l'auditeur filtre journaux, alertes et état de la chaîne d'intégrité.	M
BF-ADM-04	**Rotation des clés** — génération d'une nouvelle version, conservation des anciennes pour la détection.	S

2.8 Module PWA

L'application s'installe ; hors ligne, seule l'interface est disponible.

ID	Fonctionnalité	Prio
BF-PWA-01	**Application installable** — manifest, icônes, Service Worker (cache statique uniquement), page hors ligne informative.	M
BF-PWA-02	**Notifications** dans l'application : fin d'un traitement long, téléchargement d'une copie, alerte.	C

3. API REST

Ressource	Méthodes	Rôles autorisés	Besoins
/api/auth/{activate, login, refresh, logout, reset, mfa}	POST	Public / authentifié	BF-CPT-01 à 04
/api/datasets, /{id}/profile	GET, POST	Propriétaire (son organisation)	BF-JDD-01 à 05
/api/datasets/{id}/protect	POST	Propriétaire (MFA)	BF-WM-01 à 03, BF-STG-01
/api/recipients	GET, POST, PUT, DELETE	Gestionnaire, Propriétaire	BF-FP-01, 05
/api/distributions, /{id}/validate	GET, POST	Gestionnaire (prépare), Propriétaire (valide)	BF-FP-02, 03
/api/copies, /{id}/download	GET	Destinataire (la sienne), Propriétaire	BF-FP-04, 06
/api/investigations, /{id}/report	GET, POST	Enquêteur (les siennes), Propriétaire	BF-INV-01 à 05
/api/simulations	POST, GET	Enquêteur, Propriétaire	BF-INV-06, 07
/api/admin/**	GET, PUT	Administrateur technique (MFA)	BF-ADM-01, 02, 04
/api/audit/**	GET	Auditeur (MFA)	BF-ADM-03

Les contrôles appliqués à chaque ressource (authentification, rôle, organisation, objet) sont ceux des exigences SR-AUT et SR-AUZ (sections 4.5 et 4.6) ; l'identifiant d'un objet dans une URL n'est jamais une permission.

4. Référentiel des exigences de sécurité (SR)

4.1 Lecture du référentiel

Le cahier des charges (§10.6) annonce un référentiel d'au moins 50 exigences en 11 familles et n'en détaille que les exigences structurantes. Ce recueil le complète : **62 exigences SR**, réparties en 11 familles (CON, INT, NRP, AUT, AUZ, PRV, LOG, ERR, DIS, TST, DEP). Il sert de source au fichier docs/exigences.csv, à régénérer à chaque évolution.

— **CdC** : exigence du cahier des charges §10.6, reproduite telle quelle. Les exigences SR-INT-08, SR-INT-09, SR-INT-10 et SR-DIS-03, introduites par la v2.0, sont reportées ici comme le cahier des charges le demande.

— **SEC-xx, AB-xx, §** : exigence nouvelle, issue de la version initiale des exigences (SEC-01 à SEC-45, AB-01 à AB-11) ou d'une section du cahier des charges. La correspondance complète figure en annexe.

— **Test** : campagne de la section 7 qui doit démontrer l'exigence. Les valeurs configurables (n_{min}, limites de lignes, budgets mémoire) deviennent testables quand leur valeur, leur justification et la procédure d'essai sont figées dans la version du prototype.

— Toutes les exigences sont *proposées* (section 9). Aucune n'est déclarée vérifiée sans test exécuté.

4.2 CON — Confidentialité et secrets

ID	Exigence	Prio	Origine	Test
SR-CON-01	Les fichiers originaux et copies sont chiffrés au repos (AES-256-GCM).	P1	CdC	S1, inspection du stockage
SR-CON-02	L'original non marqué n'est jamais téléchargeable ni exposé par l'API.	P1	CdC	S1
SR-CON-03	Les clés de marquage et de signature sont dans le credential store, jamais en base ni dans le dépôt.	P1	CdC	CI (recherche de secrets), revue
SR-CON-04	Sans la clé, la présence et l'emplacement du sceau ne sont pas déterminables (positions HMAC).	P1	CdC	Revue de conception
SR-CON-05	Le fingerprinting de chaque copie utilise une sous-clé HKDF dérivée de id_jeu, version et id_copie. Le filigrane de propriété reste commun aux copies du jeu ; filigrane, sceau et empreinte utilisent des contextes de dérivation distincts. Aucune sous-clé n'est persistée en clair dans la table des distributions.	P1	SEC-16, 33	Revue de code, inspection de la base
SR-CON-06	Aucun jeton, clé ou sous-clé n'apparaît dans une URL, un téléchargement, un journal, une trace d'erreur renvoyée, une réponse d'API de métadonnées ou l'image de déploiement.	P1	SEC-04, 15, 44	S1 à S3 (journaux), CI

SR-CON-07	Toute API qui transfère des tuples ou des rapports utilise HTTPS (TLS 1.3) en déploiement ; l'authentification du transport est vérifiée avant le transfert.	P1	SEC-11	Analyse TLS du déploiement (J6)
SR-CON-08	Originaux, temporaires et copies résident en stockage serveur privé, avec autorisation API à chaque lecture ; un temporaire non finalisé n'est jamais distribué.	P1	SEC-10, 34	S3

4.3 INT — Intégrité des données, du marquage et des verdicts

ID	Exigence	Prio	Origine	Test
SR-INT-01	Chaque jeu est lié à un SHA-256 conservé à l'import.	P1	CdC	Q1, I3
SR-INT-02	Aucune modification n'excède la tolérance de la colonne ; sinon refus sans publication. Le rapport de qualité inclut les maxima et les proportions.	P1	CdC ; SEC-12	Q1
SR-INT-03	Les champs textuels pouvant être interprétés comme des formules par un tableur sont échappés lors d'un export destiné à un tableur ; les valeurs numériques signées, comme -3,5, restent valides et ne sont pas altérées à l'import. Les valeurs importées ne sont jamais modifiées silencieusement.	P1	CdC	C3
SR-INT-04	Le SHA-256 exact de chaque original et de chaque copie porte sur les octets effectivement conservés, avec schema_version et algorithm_version ; toute modification d'octet est détectable.	P1	SEC-14	I3
SR-INT-05	Le registre de distribution est signé et chaîné.	P1	CdC	I3
SR-INT-06	Une copie n'est visible qu'après contrôle des tolérances, du hash et de la cohérence registre–artefact. La publication passe par les états PENDING → VALIDATED ou FAILED, en échec fermé.	P1	SEC-18, 34	S3
SR-INT-07	Un verdict d'attribution exige un test statistique corrigé (Bonferroni) ; sinon « Indéterminé ». Les ex-aequo et les cas contradictoires restent inconclusifs.	P1	CdC ; SEC-25, 42	R4
SR-INT-08	Un import est refusé en cas de pk dupliquée ou nulle, d'en-tête dupliqué ou de renommage non reconnu ; aucune correspondance n'est inventée.	P1	CdC (v2.0) ; SEC-29, 31	C2, C3
SR-INT-09	L'identité d'une cellule est (id_jeu, version_schéma, pk, attribute_id), sérialisée à champs de longueur explicite ; sélection et bits attendus sont indépendants de l'ordre des lignes et des colonnes.	P1	CdC (v2.0) ; SEC-17, 32	C1, C4
SR-INT-10	n, k, p-valeur et seuil corrigé sont recalculés côté serveur à partir de l'extrait stocké ; le client ne les fournit jamais.	P1	CdC (v2.0)	I1
SR-INT-11	Les colonnes d'identifiant, de catégorie, de date, de code, les montants exacts et les colonnes de tolérance 0 sont exclus des cellules éligibles côté serveur, quelles que soient les valeurs envoyées par la SPA.	P1	SEC-13	Q1

SR-INT-12	Les attribute_id sont déduits du schéma versionné, jamais d'une position dans le CSV ; les en-têtes vides et les types ambigus sont rejetés.	P1	SEC-30, 31	C3
SR-INT-13	Les valeurs DECIMAL sont comparées sous une représentation canonique indépendante de la locale (21,37 et 21.37 désignent la même valeur) ; une conversion ambiguë est refusée.	P1	Version initiale	C4
SR-INT-14	Le détecteur répond « Indéterminé », sans attribution, si les clés de lignes sont absentes, si $n < n_{\min}$, si le schéma est ambigu, si le seuil n'est pas atteint ou si plusieurs candidats restent plausibles. Il vérifie les hypothèses de la statistique et la taille effective de l'échantillon.	P1	SEC-19, 24, 41	R1, R4

4.4 NRP — Non-répudiation et preuves

ID	Exigence	Prio	Origine	Test
SR-NRP-01	Chaque distribution et chaque téléchargement sont journalisés avec l'identité de l'acteur.	P1	CdC	S1
SR-NRP-02	Les rapports d'investigation sont signés (Ed25519).	P1	CdC	I2
SR-NRP-03	Tout rapport contient : organisation, jeu et version, hash de l'extrait, n, k, p-valeur, seuil, nombre N de comparaisons, conclusion, incertitudes, version du moteur et signature. Une modification ultérieure est détectée.	P1	SEC-23, 40	I1, I2
SR-NRP-04	Chaque distribution validée conserve l'identité de l'opération, l'organisation, la version du jeu, le destinataire, le hash et l'horodatage. Une correction ajoute un événement compensatoire sans effacer le précédent.	P1	SEC-20	I3

4.5 AUT — Authentification

ID	Exigence	Prio	Origine	Test
SR-AUT-01	Mots de passe hachés en Argon2id ; longueur $\geq$ 12.	P1	CdC	S1
SR-AUT-02	MFA obligatoire pour propriétaire, administrateur et auditeur.	P1	CdC	S1
SR-AUT-03	Les échecs de connexion sont limités par compte et par origine, avec une réponse uniforme et un événement d'audit sans secret ; les seuils retenus sont configurés et justifiés.	P2	SEC-03	S1
SR-AUT-04	JWT ES256, durée $\leq$ 15 min, refresh avec rotation.	P1	CdC	S1
SR-AUT-05	Une opération privée sans identité serveur valide est refusée (401) avant toute lecture de données, génération de copie ou consultation du registre.	P1	SEC-01	S1
SR-AUT-06	Un lien de téléchargement est à usage limité et expire sous 24 h.	P1	CdC	S1

4.6 AUZ — Autorisation

ID	Exigence	Prio	Origine	Test
SR-AUZ-01	Refus par défaut ; matrice des droits appliquée côté serveur.	P1	CdC	S1
SR-AUZ-02	Tout accès à un jeu, une copie ou un rapport vérifie l'organisation et la ressource (pas d'IDOR).	P1	CdC ; SEC-05	S1
SR-AUZ-03	Une distribution n'est générée qu'après validation par un propriétaire différent du préparateur.	P1	CdC	S1
SR-AUZ-04	L'autorisation est réévaluée au lancement d'un job et avant sa publication ; un job dont l'autorisation a été révoquée ou a expiré avant le commit ne publie rien.	P1	SEC-02, 35	S1, S3
SR-AUZ-05	Un accès révoqué interdit tout nouveau téléchargement immédiatement.	P1	CdC	S1
SR-AUZ-06	L'administrateur technique n'a aucun accès aux jeux, copies ni clés.	P1	CdC ; SEC-06	S1
SR-AUZ-07	Chaque téléchargement vérifie en base l'état de la distribution (VALIDATED, non REVOKED), l'expiration, le quota, l'organisation et le destinataire associé ; un lien seul ne constitue pas une autorisation.	P1	SEC-07, 36	S1

4.7 PRV — Vie privée et confidentialité des associations

ID	Exigence	Prio	Origine	Test
SR-PRV-01	Les associations copie/destinataire ne sont visibles que par les rôles habilités.	P1	CdC ; SEC-08	S1
SR-PRV-02	Seules des données synthétiques ou publiques sont utilisées en test.	P1	CdC	Revue
SR-PRV-03	L'intégrité du registre est vérifiée avant toute association nominative dans un rapport ; en cas d'échec, l'association est déclarée non fiable.	P1	SEC-43	I3

4.8 LOG — Journalisation et audit

ID	Exigence	Prio	Origine	Test
SR-LOG-01	Journal d'audit chaîné, en ajout seul ; accès en lecture réservé à l'auditeur.	P1	CdC ; SEC-22	I4
SR-LOG-02	Alerte sur volume anormal de téléchargements ou d'investigations.	P2	CdC	S1
SR-LOG-03	Imports, erreurs de schéma, échecs d'autorisation, marquages, téléchargements, investigations et révocations produisent des événements corrélés par identifiant de traitement, sans valeur de tuple brute ni clé.	P1	SEC-21, 39	S1 à S3 (journaux)
SR-LOG-04	Un contrôle de cohérence entre registre, copies et audit détecte une relation destinataire ou un hash modifié directement en base.	P1	AB-08	I3

4.9 ERR — Gestion des erreurs

ID	Exigence	Prio	Origine	Test
SR-ERR-01	Erreurs au format RFC 9457, sans trace interne ni secret.	P1	CdC	C2, C3, S2
SR-ERR-02	Un rejet d'import (collision, schéma, quota) renvoie un code et un message non révélateurs, sans valeur de tuple, et produit un événement d'audit.	P1	AB-02	C2, S2

4.10 DIS — Disponibilité et résilience du code métier

ID	Exigence	Prio	Origine	Test
SR-DIS-01	Traitements dans une file bornée avec timeout de 60 s.	P1	CdC	S2, Q2
SR-DIS-02	Fichiers limités à 50 Mo et 1 000 000 lignes ; schéma validé avant traitement.	P1	CdC ; SEC-09	S2
SR-DIS-03	Lecture du CSV et des résultats JDBC en flux par lots bornés ; nombre de colonnes, longueur de ligne et jobs concurrents bornés ; aucun jeu complet chargé en mémoire.	P1	CdC (v2.0) ; SEC-26, 37, 38	S2, Q2
SR-DIS-04	Des quotas par organisation bornent les traitements, les téléchargements par destinataire et les investigations par enquêteur ; le dépassement renvoie 429.	P2	BF-ADM-02 ; CdC §9.4	S2
SR-DIS-05	En cas de timeout, d'exception, d'annulation ou de reprise, aucun artefact partiel n'est publié ; le job reste dans un état explicite et ses temporaires sont supprimés.	P1	SEC-27	S3
SR-DIS-06	Une restauration de test retrouve la cohérence entre registre, copies chiffrées, versions de clé et audit sans exposer les secrets ; aucune décision automatique ne s'appuie sur un registre restauré non vérifié.	P2	SEC-28	S4 (J6)

4.11 TST — Vérification et preuves

ID	Exigence	Prio	Origine	Test
SR-TST-01	Une exigence n'est déclarée vérifiée qu'après l'exécution d'un test reproductible dont les observations sont conservées.	P1	Version initiale	Revue d'inspection
SR-TST-02	Les faux positifs sont évalués sur un corpus de témoins non marqués, avec un intervalle d'incertitude et le modèle d'attaque associé.	P1	SEC-24	R4
SR-TST-03	Chaque commit remonte à une issue, une exigence et un test.	P2	Version initiale	Revue du dépôt
SR-TST-04	Chaque cas d'abus est couvert par un test démontrant l'échec de l'attaque.	P1	CdC	S1 à S3, I1 à I4
SR-TST-05	Les mesures de latence p95 et de mémoire déclarent la charge, la machine et la JVM ; une exécution isolée ne valide pas un SLO p95.	P1	SEC-45	Q2

4.12 DEP — Déploiement et chaîne de livraison

ID	Exigence	Prio	Origine	Test
SR-DEP-01	Le secret qui protège le credential store n'est ni dans le dépôt, ni dans la base, ni à côté du fichier du store ; il est injecté au démarrage.	P1	CdC §6.5	CI, revue
SR-DEP-02	Les procédures de restauration et de rotation des clés sont documentées et testées ; les anciennes versions de clé restent disponibles pour la détection.	P2	CdC §6.5 ; BF-ADM-04	S4 (J6)
SR-DEP-03	Recherche de secrets en CI ; conteneurs non root ; en-têtes de sécurité.	P1	CdC	CI

5. Cotation des risques (OWASP Risk Rating)

Calcul reproductible et statut des cotations

Pour chaque risque, documenter séparément quatre facteurs d'agent menaçant, quatre facteurs de vulnérabilité, quatre facteurs d'impact technique et quatre facteurs d'impact métier (tous cotés de 0 à 9). La vraisemblance résulte de la moyenne des deux premiers groupes ; les impacts sont cotés et justifiés séparément. Reporter le résultat dans la matrice OWASP, puis refaire la cotation après les contre-mesures en explicitant les facteurs modifiés. Le niveau affiché dans la table suivante est **préliminaire** et n'est pas une cotation OWASP calculée tant que la feuille détaillée n'est pas remplie.

Exemple illustratif de cotation non validée – R-01 (IDOR). Supposons les notes fictives d'agent $(6, 7, 7, 7)$ et de vulnérabilité $(7, 7, 8, 6)$: moyennes respectives 6,75 et 7, donc vraisemblance indicative 6,875. Supposons des notes d'impact technique $(8, 8, 2, 5)$ (moyenne 5,75) et d'impact métier $(7, 8, 7, 8)$ (moyenne 7,5). Ces chiffres ne constituent *ni un résultat de test ni une note validée.* Une fois les tests d'autorisation et les limites d'accès démontrés, l'équipe estimera la vraisemblance résiduelle, sans présumer que l'impact potentiel a disparu.

Le cahier des charges cite la méthode OWASP Risk Rating parmi ses références sans en donner la cotation. Pour chaque scénario, l'équipe décrit les facteurs de l'agent menaçant (compétence, motivation, opportunité, taille du groupe), les facteurs de vulnérabilité (facilité de découverte et d'exploitation, connaissance, détection), les impacts techniques (confidentialité, intégrité, disponibilité, responsabilité) et les impacts métier (préjudice financier, réputation, non-conformité, vie privée), sur l'échelle OWASP de 0 à 9.

Le tableau donne une première évaluation argumentée. Ces niveaux sont des hypothèses à discuter collectivement. La cotation finale exigera la feuille de facteurs renseignée et signée par l'équipe, puis la comparaison avant et après contre-mesure. Aucune note numérique n'est présentée ici comme définitive.

ID	Scénario	CA	Prob.	Impact	Niveau proposé et justification	SR principales
R-01	Un utilisateur authentifié obtient la copie d'un autre destinataire ou d'une autre organisation	CA-02, CA-11	Élevée	Élevé	**Critique** : compte déjà authentifié, API accessible, fuite inter-organisation	SR-AUZ-02, 05, 07
R-02	Désynchronisation clé / attribut / tuple (collision, permutation, renommage)	CA-13, CA-14	Moyenne	Élevé	**Élevé** : peut anéantir la traçabilité ou produire une fausse attribution	SR-INT-08, 09, 12, 13
R-03	Gestionnaire ou propriétaire altère le registre	CA-07, CA-17	Moyenne	Élevé	**Élevé** : perte de la preuve, attribution erronée	SR-INT-05, SR-NRP-04, SR-LOG-04

R-04	CSV saturant la heap ou le CPU	CA-06	Élevée	Moyen	**Élevé** : faible coût pour un compte autorisé, déni de service métier	SR-DIS-01 à 05
R-05	Enquêteur force une conclusion	CA-15	Moyenne	Élevé	**Élevé** : suspicion injustifiée d'un destinataire, atteinte à la confiance	SR-INT-07, 10, 14, SR-NRP-02
R-06	Suppression massive ou nettoyage des cellules marquées par un destinataire	CA-04, CA-16	Élevée	Moyen	**Élevé** : possible après téléchargement ; risque résiduel assumé	SR-INT-07, 14, SR-LOG-02
R-07	Collusion de plusieurs destinataires	CA-03	Moyenne	Moyen	**Moyen** : limite assumée du MVP ; le filigrane commun est préservé	Hors périmètre

Pourquoi pas DREAD ? Ses cinq notes (dommages, reproductibilité, exploitabilité, personnes affectées, découvrabilité) ont des définitions et des pondérations souvent peu stables d'un évaluateur à l'autre, et sont moins directement reliées à l'impact métier. CVSS convient mieux à une vulnérabilité technique identifiée qu'à un scénario métier encore en conception. Une note sans facteurs ni justification n'est pas suffisante.

6. Indicateurs SLI et objectifs SLO du code métier

Un **SLI** est une mesure observée sur le fonctionnement du service métier ; un **SLO** est la cible associée, révisable après la première campagne de mesures (jalon J2) sur un environnement déclaré (machine, JVM, jeu de données). Les exigences ENF-01 à ENF-08 sont dans le cahier des charges (§8.1) ; les valeurs ci-dessous sont des cibles à confirmer par le prototype du jalon J2 et seront ajustées, avec justification, dans la version suivante du document.

6.1 SLI et SLO initiaux

SLI	Définition	SLO initial proposé	Preuve prévue
validation_sûre	Imports interdits rejetés / imports interdits soumis	100 % sur le corpus de validation	Campagnes C2 à C4 et S2 : doublons de pk, pk nulles, en-têtes dupliqués, types imprévus, CSV hostile, formules (CA-05, CA-14)
distorsion_conforme	Copies publiées avec erreur $\leq$ tolérance / copies publiées	100 % (ENF-04)	Q1 : comparaison entrée/sortie, colonne par colonne
copie_atomique	Distributions complètes et vérifiables / distributions validées	100 %	S3 : arrêt forcé avant commit, état FAILED, aucune copie partielle accessible
réordonnancement	Extraits reconnus à l'identique après permutation de lignes et de colonnes / essais	100 % (ENF-05, ENF-08)	C1 : test métamorphique reproductible, 100 permutations (CA-13)
ber_filigrane (taux d'erreur d'extraction)	Bits de filigrane mal extraits / bits attendus, sur copie complète	0 % sans attaque ; $\leq$ 1 % sous bruit $\leq \delta/4$	R1, R2 : banc de 30 jeux ; la quantification garantit en théorie un taux nul sous $\delta/4$, la marge de 1 % couvre les arrondis décimaux
récupération_sceau	Sceaux décodés (Reed-Solomon, signature valide) / sceaux insérés, sur extraits testés dont la capacité suffisante est validée	$\geq$ 99 %	R1 : banc ; sceau actif seulement si la capacité est validée
attribution_correcte	Copies identifiées / copies évaluables, sur extrait $\geq$ 20 % des lignes	$\geq$ 95 % (ENF-07)	R1 : jeu $\geq$ 100 000 lignes, $\leq$ 30 destinataires
faux_positifs	Témoins non marqués reconnus à tort / témoins	0 sur 1 000 ; p $< 10^{-6}$ par test (ENF-06)	R4 : $\geq$ 1 000 témoins ; intervalle d'incertitude rapporté (SR-TST-02)

indétermination	Extraits rendus « Indéterminé » / extraits évalués, par transformation	Publié, sans cible	R1, R2 : courbes de robustesse
latence_protection_p95	95e centile de la durée de protection	$\leq$ 60 s pour 100 000 lignes (ENF-01, 4 vCPU)	Q2 : 20 essais ; CPU et heap mesurés
latence_investigation_p95	95e centile de la durée d'investigation	$\leq$ 30 s pour 10 000 lignes et 30 destinataires (ENF-02)	Q2 : 20 essais
erreur_heap	Traitements échoués par OutOfMemoryError / traitements conformes	0 sur un lot d'essai borné	S2, Q2 : stress test sur quotas et concurrence définis ; plafond de heap fixé à J2 (CdC §9.4)
reprise_sûre	Copies accessibles sans registre validé après un arrêt de processus injecté en cours de job	0	S3 : arrêt forcé, reprise, durée de nettoyage d'un temporaire mesurée

6.2 Protocole de mesure

Le cahier des charges (§8.2) renvoie à ce recueil pour les méthodes de collecte, les seuils d'alerte et les fenêtres de mesure. Les valeurs ci-dessous sont proposées et seront confirmées au jalon J2.

SLI	**Méthode de collecte**	**Fenêtre de mesure**	**Seuil d'alerte (proposé)**
validation_sûre	Compteur des imports interdits acceptés, par exécution de C2 à C4 et S2	Chaque exécution de la suite en CI	Un seul import interdit accepté : échec bloquant
distorsion_conforme	Comparaison colonne par colonne, entrée et sortie, par le moteur avant publication	Chaque copie produite	Une seule copie hors tolérance : publication bloquée et alerte
copie_atomique	Contrôle de cohérence registre–artefact	Chaque distribution et chaque essai S3	Toute copie accessible sans registre validé
réordonnancement	100 permutations aléatoires par jeu canonique	Chaque nouvelle version du moteur	Une seule décision divergente
ber_filigrane	Bits mal extraits / bits attendus sur le banc de 30 jeux	R1 et R2, par version du moteur	> 0 % sans attaque ; > 1 % sous bruit $\leq \delta/4$
récupération_sceau	Sceaux décodés / insérés sur extraits dont la capacité suffisante est validée	R1, jeux dont le test préalable de capacité et de décodage a réussi	< 99 %
attribution_correcte	Copies identifiées / évaluables sur extrait $\geq$ 20 %	R1, jeu $\geq$ 100 000 lignes	< 95 %
faux_positifs	Témoins reconnus à tort / témoins, avec intervalle d'incertitude	R4, $\geq$ 1 000 témoins par version du moteur	Une seule fausse attribution
indétermination	Part d'extraits « Indéterminé » par transformation et par proportion de lignes conservées	R1 et R2	Aucune alerte : courbes publiées
latence_*_p95	p50 et p95 de l'import, du marquage et de l'investigation, selon le nombre de tuples, de colonnes et de destinataires	Q2, 20 essais, machine et JVM déclarées	p95 supérieur au SLO ; un seul essai ne valide rien (SR-TST-05)
erreur_heap	OutOfMemoryError / traitements conformes ; pic de heap par volume	S2 et Q2	Toute OutOfMemoryError
reprise_sûre	Copies accessibles sans registre validé après arrêt injecté ; durée de nettoyage	S3, à chaque version du moteur	Une seule copie accessible

6.3 Lecture des indicateurs

Taux d'erreur d'extraction des marques. L'indicateur ber_filigrane mesure directement la qualité de l'extraction : sur une copie non attaquée il doit être nul, et il ne peut croître qu'avec une transformation documentée (bruit, arrondi, suppression), dont l'effet est mesuré par le simulateur. Au-delà du domaine ENF-05, le système ne dégrade pas la qualité de la décision : il passe en « Indéterminé ».

Cible n'est pas résultat. Aucune valeur de performance ou de robustesse n'est revendiquée comme validée avant la production des journaux de tests. Un taux réel de faux positifs de 10^{-6} ne se

démontre pas par un banc de 1 000 témoins : une série sans erreur borne seulement le taux à $\approx 0{,}3$ % (règle des trois, niveau 95 %). La garantie de 10^{-6} repose donc sur le modèle binomial et sur la validation expérimentale de l'hypothèse nulle (bits indépendants et équiprobables), justifiées au jalon J2 avec le nombre effectif de positions indépendantes et les comparaisons multiples (Bonferroni).

Précautions statistiques. Une p-valeur théorique n'est pas une mesure empirique des faux positifs : ceux-ci s'évaluent sur un jeu témoin non marqué, avec un intervalle de confiance. Une p-valeur n'est jamais convertie en probabilité de culpabilité. La robustesse à la suppression de lignes et à l'arrondi est publiée comme une courbe (transformation × proportion de tuples restants → taux de détection et d'indétermination), non comme un SLO général de détection fixé avant le modèle d'attaque et la mesure du banc.

7. Campagnes de vérification

7.1 Principes

Les campagnes alimentent les SLI et démontrent les exigences SR. Chaque exécution conserve le jeu synthétique et sa graine, la version du moteur, le nombre de tuples, les paramètres de seuil, la configuration, la machine et la JVM, la durée et un résultat explicite (CdC §11.5). Les rapports qui comportent des échecs sont aussi documentés que ceux qui réussissent ; les tests qui échouent ou ne permettent pas de conclure sont également documentés pour mieux comprendre les limites du moteur. La réussite du MVP signifie la validation d'un périmètre d'attaque défini, pas l'absence de vulnérabilités.

Les jeux d'essai sont synthétiques ou publics (SR-PRV-02). Le banc, le simulateur et les paramètres de transformation sont ceux du cahier des charges (§11.1, §11.2). Les journaux produits par les campagnes sont inspectés : aucun tuple brut, aucune clé (SR-LOG-03).

7.2 Catalogue des campagnes

ID	Manipulation et jeu d'essai	Observation attendue et preuve archivée	Liens
Q1	Marquage de colonnes DECIMAL sur le banc (30 jeux, trois tailles)	Écart maximal et moyen ≤ tolérance ; moyenne et variance conformes à ENF-04 ; rapport de qualité archivé	distorsion_conforme, SR-INT-02, 11
Q2	Protection (10 000 et 100 000 lignes) et investigation (10 000 lignes, 30 destinataires), 20 essais, serveur 4 vCPU déclaré	p50, p95 et pic de heap par volume ; comparaison G1 et ZGC générationnel ; journaux GC conservés	latence, erreur_heap, SR-TST-05
C1	100 permutations aléatoires des lignes et des colonnes d'un même jeu canonique	Mêmes cellules sélectionnées, mêmes bits extraits, même verdict avant et après	réordonnancement, CA-13, SR-INT-09
C2	pk nulle, pk dupliquée, import sans clé stable déclarée	Rejet avant tout marquage ; aucun fichier final visible ; événement d'audit sans valeur de tuple	validation_sûre, CA-14, SR-INT-08, SR-ERR-02
C3	En-têtes vides ou dupliqués, renommage non reconnu, types ambigus, valeurs DECIMAL hors plage, CSV malformé, champs textuels à formule et nombres négatifs conservés	Rejet documenté (RFC 9457) ou neutralisation ; aucun artefact final	validation_sûre, CA-05, SR-INT-03, 12
C4	Champs conçus pour mettre en échec une concaténation naïve (12,34 et 1,234) ; valeurs 21,37 et 21.37	Identités de cellule distinctes pour des entrées distinctes ; même valeur canonique pour 21,37 et 21.37	CA-14, SR-INT-09, 13

R1	Retrait de 10 à 80 % des lignes sur le banc	Courbe de détection, taux d'indétermination, ber_filigrane, récupération du sceau, attribution	indétermination, SR-INT-14, CA-04, CA-16
R2	Arrondi ($\geq \delta$ puis 2δ), bruit $\delta/8$, $\delta/4$, $\delta/2$, suppression d'une colonne marquée, combinaison suppression 50 % et bruit $\delta/4$	Perte de marque mesurée ; verdicts « Indéterminé » justifiés ; aucune attribution forcée	CA-04, CA-16
R3	Comparaison de plusieurs copies	Limite de la collusion documentée ; filigrane commun toujours détecté	CA-03
R4	$\geq$ 1 000 extraits non marqués ; séries de candidats multiples soumises par un même enquêteur	0 fausse attribution ; taux de décisions positives avec intervalle d'incertitude ; seuil α/N rapporté	faux_positifs, CA-12, SR-INT-07, SR-TST-02
S1	Deux organisations et un compte par rôle : requêtes anonymes ou à jeton expiré, échecs de connexion répétés, accès croisés par identifiant, téléchargement après révocation, rejeu de lien, auto-validation, lecture d'un jeu par l'administrateur	Refus uniforme (401, 403 ou 404) ; événement de sécurité sans tuple brut ni clé	CA-02, 10, 11, 18, SR-AUT, SR-AUZ
S2	CSV hors quota, ligne abusive, trop de colonnes, deux imports simultanés, dépassement de file	Rejet 413, 422 ou 429 sans épuisement de heap ; aucun temporaire accessible	erreur_heap, CA-06, SR-DIS-01 à 05
S3	Arrêt de processus, timeout ou annulation en cours de job ; révocation avant le commit	État FAILED ; aucune copie partielle accessible ; temporaires nettoyés ; reprise propre	copie_atomique, reprise_sûre, SR-INT-06, SR-DIS-05, SR-AUZ-04
S4	Restauration de test de la base, des copies chiffrées et des versions de clé (jalon J6)	Cohérence registre, copies, clés et audit retrouvée ; aucun secret exposé ; décision automatique refusée sur un registre non vérifié	SR-DIS-06, SR-DEP-02
I1	Requête d'investigation avec n, k, p-valeur ou seuil fournis par le client	Valeurs ignorées ; recalcul côté serveur	CA-15, SR-INT-10
I2	Rapport exporté puis altéré (p-valeur, candidat)	Signature invalide détectée	CA-09, CA-15, SR-NRP-02, 03
I3	Modification en base d'un destinataire, d'un hash ou d'une relation copie–destinataire ; tentative de changer l'association après validation	Détection par le contrôle de cohérence et la vérification de chaîne ; association modifiée refusée ; registre inchangé	CA-07, CA-17, SR-INT-05, SR-NRP-04, SR-LOG-04
I4	Édition ou suppression d'un événement du journal	Vérification de chaîne en échec	CA-18, SR-LOG-01

8. Traçabilité

Chaque changement de code doit permettre de remonter à une issue, une exigence et un test (SR-TST-03). Les matrices ci-dessous ne sont pas une preuve d'implémentation tant que les tests ne sont pas exécutés.

8.1 Modules fonctionnels et exigences de sécurité

Module	Exigences SR principales
Socle (BF-CPT)	SR-AUT-01 à 06, SR-AUZ-01, SR-PRV-01, SR-ERR-01
Jeux de données (BF-JDD)	SR-INT-01, 03, 04, 08, 11, 12, 13 ; SR-DIS-01 à 04 ; SR-CON-01, 08 ; SR-ERR-02
Watermarking (BF-WM)	SR-INT-02, 06, 09, 11 ; SR-CON-04, 05
Stéganographie (BF-STG)	SR-CON-03, 04, 05 ; SR-INT-04 ; SR-DEP-01, 02

Fingerprinting (BF-FP)	SR-AUZ-02 à 07 ; SR-AUT-06 ; SR-CON-02, 08 ; SR-INT-05, 06 ; SR-NRP-01, 04 ; SR-PRV-01
Investigation (BF-INV)	SR-INT-07, 10, 14 ; SR-NRP-02, 03 ; SR-PRV-03 ; SR-TST-02
Administration (BF-ADM)	SR-AUZ-06 ; SR-LOG-01 à 04 ; SR-DIS-04 ; SR-CON-03 ; SR-DEP-01, 02
PWA (BF-PWA)	SR-CON-06, 07 ; SR-DEP-03 ; SR-ERR-01
Transverse	SR-TST-01, 03, 04, 05 ; SR-DIS-05, 06 ; SR-LOG-03

8.2 Cas d'abus, exigences et campagnes

CA	Scénario	Exigences SR	Campagnes
CA-01	Redistribution d'une copie reçue	SR-INT-05, SR-NRP-04, SR-INT-14	R1
CA-02	IDOR inter-organisation	SR-AUZ-02, 07	S1
CA-03	Collusion de copies	Limite assumée (CdC §6.6)	R3
CA-04	Atténuation des marques	SR-INT-07, 14	R1, R2
CA-05	Injection de formules CSV	SR-INT-03	C3
CA-06	Fichier piégé ou volumineux	SR-DIS-01 à 05, SR-ERR-02	S2
CA-07	Falsification du registre	SR-INT-05, SR-NRP-04, SR-LOG-04	I3
CA-08	Vol de la clé maître	SR-CON-03, 05, 06 ; SR-DEP-01, 03	CI ; journaux de S1 à S3
CA-09	Falsification d'un rapport	SR-NRP-02, 03	I2
CA-10	Auto-validation	SR-AUZ-03	S1
CA-11	Téléchargement après révocation, rejeu de lien	SR-AUZ-05, 07 ; SR-AUT-06	S1
CA-12	Fausse attribution	SR-INT-07, 14 ; SR-TST-02	R4
CA-13	Permutation, renommage	SR-INT-09, 12	C1, C3
CA-14	Collision d'identité	SR-INT-08, 13 ; SR-ERR-02	C2, C4
CA-15	Enquêteur corrompu	SR-INT-10 ; SR-NRP-02, 03	I1, I2
CA-16	Nettoyage de l'empreinte	SR-INT-09, 14 ; SR-LOG-02	R1, R2
CA-17	Complicité gestionnaire et propriétaire	SR-AUZ-03 ; SR-INT-05 ; SR-NRP-04 ; SR-LOG-02, 04	S1, I3
CA-18	Administrateur, auditeur, développeur	SR-AUZ-06 ; SR-LOG-01 ; SR-CON-06 ; SR-DEP-03	S1, I4

9. Gestion des exigences et inspection croisée

9.1 Statuts

Une exigence passe par les statuts *proposée*, *validée* (acceptée par l'équipe), *implémentée*, *vérifiée* (un test exécuté dont les observations sont conservées) et *à revoir*. Elle ne peut pas être déclarée vérifiée uniquement parce qu'elle figure dans un document (SR-TST-01). Ces statuts restent distincts pour ne pas confondre spécification et réalisation.

9.2 Checklist d'inspection

Avant chaque commit final, un autre membre de l'équipe vérifie, pour chaque exigence :

— qu'elle cite un objet concret de TupleTrace et une frontière de confiance (F1 à F4) ;

— qu'elle exprime un seul comportement compréhensible et un effet observable de succès ou d'échec ;

— que sa priorité est motivée et qu'elle est reliée à un actif et à une menace (CA) ;

— qu'un test reproductible existe, que les valeurs cibles sont marquées « proposées » tant qu'elles ne sont pas mesurées, et que le seuil et les limites du modèle statistique sont expliqués ;

— qu'elle ne contredit aucune autre exigence, ni le cahier des charges ;

— que son statut réel est à jour.

9.3 Conflits résolus

1. **Robustesse et qualité.** Plus un marquage est robuste, plus il peut affecter l'utilité : les tolérances métier priment et un marquage impossible échoue (BF-WM-03, SR-INT-02).
2. **Identité du candidat et confidentialité.** L'investigation doit nommer une copie sans exposer le destinataire : seuls les rôles habilités voient l'association (SR-PRV-01, SR-PRV-03).
3. **Audit et données sensibles.** Le journal contient des identifiants et des hashes, jamais des tuples complets (SR-LOG-03).
4. **Interruption.** Une interruption préserve l'intégrité avant la disponibilité : échec fermé pour la publication, reprise explicite et réessai contrôlé (SR-INT-06, SR-DIS-05).
5. **Attribution et preuve.** L'attribution ne dépasse jamais la solidité de la preuve : statut « Indéterminé » en cas de doute (SR-INT-14).
6. **Accès de l'administrateur.** Un accès exceptionnel de l'administrateur technique aux données métier, examiné dans la version initiale (SEC-06), n'est pas retenu : le cahier des charges interdit tout accès aux jeux, copies et clés (SR-AUZ-06, CA-18).

10. Risques liés à la fiabilité et risques résiduels

10.1 Risques de fiabilité

Risque	Impact	Parade
Saturation de la heap Java sur gros volumes	Traitement interrompu, déni de service	Lecture en flux, lots et file bornés, tests de charge (SLI erreur_heap, campagnes S2 et Q2)
Marquage non robuste après transformation	OM-3 partiellement atteint	Prototype dès J2 sur le banc ; pas δ ajustable ; redondance et code correcteur réglables ; verdict « Indéterminé »
Cibles de performance non tenues	ENF-01 et ENF-02 non atteints	Profilage dès J2 ; valeurs de départ révisées avec justification

10.2 Risques résiduels du MVP

Les risques suivants ne sont pas résolus par le MVP. Ils figurent dans les rapports plutôt que d'être masqués sous des exigences génériques de chiffrement.

— Aucun marquage tabulaire n'est infaillible contre la suppression massive d'enregistrements, la suppression des clés stables, les agrégations destructrices ou la collusion de plusieurs destinataires (R-06, R-07).

— Une fuite qui survient après le téléchargement échappe au contrôle d'accès de la plateforme.

— Un serveur compromis pendant un traitement peut observer les tuples en clair (CdC §9.5).

— Un extrait réellement issu de la copie d'un tiers révèle légitimement la marque de ce tiers : le rapport reste un indice technique, jamais une preuve de responsabilité (CA-15).